CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

CUADERNO DE GRUPO UT1

- **Nombre del grupo: Jackis**

- **Nombre de los alumnos:**
  - **Isela Pilar González Primo**
  - **Jorge Higuero Peña**

- **Módulo: Incidentes de Ciberseguridad**

CURSO 2026-2027

Contenido

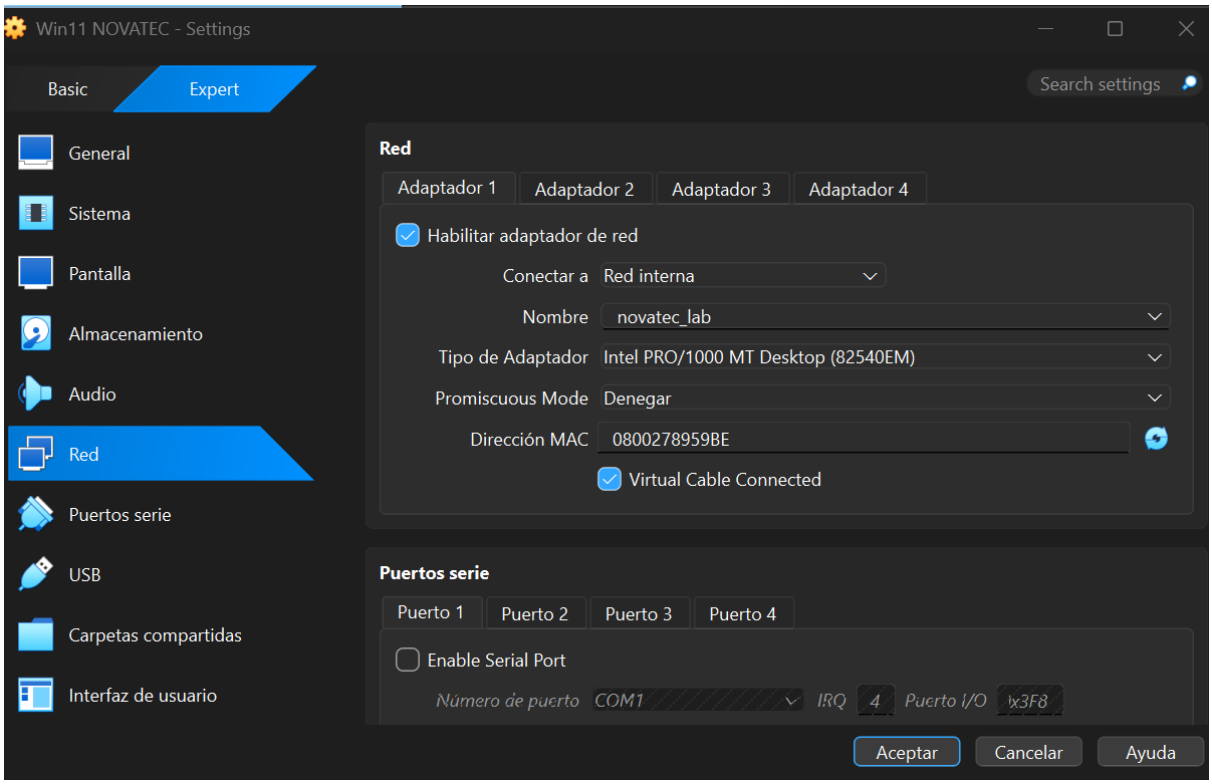
PRÁCTICA 3: OPERACIÓN "FACTOR HUMANO" 2
1. Contexto Profesional y Delimitación del Laboratorio (Fase 0) 2
2. Marco de Gobierno, Normativa y Matriz de Riesgos (E1 - Fase 1) 4
2.1. Cinco Principios Corporativos de Seguridad 4
2.2. Seis Normas Auditables de Puesto y Comunicación 4
2.3. Procedimiento de Notificación en 4 Pasos 4
2.4. Matriz de 6 Riesgos Evaluados 5
2.5. Acta Simulada de Aprobación de Dirección 5
3. Despliegue de Correo Local y Dos Campañas GoPhish (E2 y E3) 6
4. Telemetría y Análisis Técnico (Fase 4) 16
4.1. Captura e Inspección de Tráfico de Red (tcpdump / Wireshark) 16
4.2. Correlación de Registros y Confinamiento del Panel 17
5. Plan de Formación, Seguimiento y Métricas (E4 y E5) 18
5.1. Microformación de 5 minutos para Administración y Guía Visual 18
5.2. Cuestionario de Evaluación de Decisiones (6 Ítems) 19
5.3. Sistema de Indicadores (KPI / KRI) 20
6. Auditoría Cruzada y Mejora Continua (E6 - Fase 6) 21
6.1. Matriz de Auditoría (8 Requisitos Clave) 21
7. Anexo: Inteligencia de Ciberamenazas y Monitorización en Fuentes Públicas de Telegram (Enfoque OSINT / CTI) 21
7.1. Implementación Técnica: Indexador Automatizado de CTI en Telegram 22

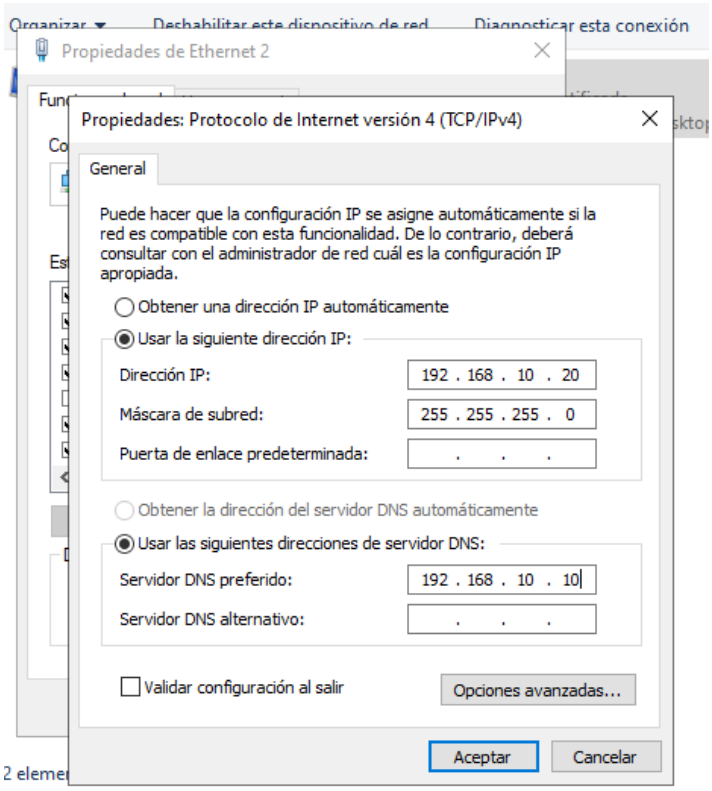
PRÁCTICA 3: OPERACIÓN "FACTOR HUMANO"

1. Contexto Profesional y Delimitación del Laboratorio (Fase 0)

NOVATEC ha identificado deficiencias críticas en la detección temprana de incidentes de ingeniería social, especialmente demoras en la notificación de mensajes sospechosos. Dirección General ha solicitado un plan de choque a 90 días con evidencias auditables.

- **Entorno técnico:** Despliegue en red aislada de VirtualBox ("Red Interna").
  - **VM1 (Ubuntu 24.04 Server):** Aloja el servidor SMTP (Postfix), IMAPS con TLS (Dovecot), el gestor de simulación (GoPhish) y monitorización de registros. IP asignada: 192.168.10.10/24. **Se implementa además un servicio de resolución de nombres local mediante BIND9 para resolver mail.novatec.test hacia la IP 192.168.10.10, garantizando compatibilidad con registros MX en clientes estándar.**
  - **VM2 (Windows 11):** Emula la estación de trabajo del empleado corporativo bajo el cliente Mozilla Thunderbird y navegador web local. IP asignada: 192.168.10.20/24 (servidor DNS preferido: 192.168.10.10, sin puerta de enlace).





- **Límites éticos y legales (Reglas de Engagement):** Dominio exclusivo reservado novatec.test. Prohibida la salida de tráfico SMTP a Internet, recogida de credenciales o uso de adjuntos ejecutables reales. Todo hallazgo se categoriza en: Demostrado en laboratorio, Simulado o Propuesto para implantación.

2. Marco de Gobierno, Normativa y Matriz de Riesgos (E1 - Fase 1)

2.1. Cinco Principios Corporativos de Seguridad

1. **Defensa en profundidad:** La seguridad no descansa únicamente en el filtro perimetral; combina controles técnicos en el servidor de correo, configuración segura de puesto y capacitación continua del usuario.
2. **Mínimo privilegio:** Las cuentas de usuario (empleado@novatec.test) carecen de permisos de administración local en Windows y privilegios innecesarios en el buzón.
3. **Autenticidad y verificación:** Toda orden relativa a pagos, emisión de facturas o cambios de acceso exige verificación obligatoria por un canal secundario establecido.
4. **Trazabilidad y no repudio:** Cada flujo de correo y cada reporte de incidente almacena sellos temporales y cabeceras completas verificables mediante logs (journalctl, registros de GoPhish).
5. **Cultura justa y no punitiva:** Se promueve la notificación sin miedo a represalias. Un error operativo notificado a tiempo se considera un dato de mejora, nunca una falta sancionable.

2.2. Seis Normas Auditables de Puesto y Comunicación

- **NOR-01 (Uso de correo corporativo):** La cuenta @novatec.test se destina estrictamente a actividades profesionales; prohibido su uso para servicios personales o plataformas no autorizadas.
- **NOR-02 (Gestión de hipervínculos):** Queda prohibido hacer clic en enlaces embebidos que soliciten acciones inmediatas o accesos a portales externos sin contrastar previamente el dominio visible con la URL real.
- **NOR-03 (Tratamiento de adjuntos):** Prohibida la apertura de ficheros adjuntos con extensiones potencialmente peligrosas (.zip protegidos, macros, scripts) procedentes de remitentes no verificados.
- **NOR-04 (Gestión de credenciales y MFA):** Ningún administrador ni directivo solicitará jamás credenciales por correo. Las claves corporativas no se introducen en ningún enlace recibido por mensaje.
- **NOR-05 (Obligación de notificación):** Cualquier correo anómalo o sospechoso debe ser notificado al buzón de seguridad en un plazo máximo de 60 minutos tras su recepción.
- **NOR-06 (Seguridad física del puesto de trabajo):** Bloqueo obligatorio del equipo (Win + L) ante ausencias temporales y prohibición de alterar configuraciones de red o excepciones de certificados sin autorización.

2.3. Procedimiento de Notificación en 4 Pasos

1. **Paso 1 (Identificación e interrupción):** Al detectar incongruencias (urgencia inusual, incoherencias en el remitente), el usuario interrumpe la interacción sin abrir enlaces ni adjuntos.
2. **Paso 2 (Aislamiento y reenvío):** Se reenvía el correo como adjunto (para preservar cabeceras completas) al canal interno seguridad@novatec.test.
3. **Paso 3 (Recepción y triage):** El equipo de seguridad genera acuse de recibo automatizado, clasifica la amenaza y registra la telemetría del intento.
4. **Paso 4 (Protección y contención):** En caso de interacción accidental previa, se aísla preventivamente la sesión sin penalizar al empleado y se refuerza la monitorización del buzón.

2.4. Matriz de 6 Riesgos Evaluados

ID	Amenaza / Escenario	Prob.	Impacto	Nivel	Tratamiento / Controles Propuestos PDF
R-01	Suplantación en factura urgente a administración (C1)	Media	Muy Alto	**Crítico**	Doble factor en autorizaciones de pago y análisis de cabeceras SMTP.
R-02	Robo de credenciales técnicas vía falso aviso de acceso (C2)	Alta	Alto	**Alto**	Despliegue de MFA forzoso y simulación periódica con GoPhish.
R-03	Ejecución de malware por descarga de adjunto armado	Media	Muy Alto	**Crítico**	Filtrado estricto en Postfix y desactivación de macros en puesto cliente.
R-04	Reporte tardío u omisión de notificación por miedo al castigo	Alta	Medio	**Medio**	Adopción de política de Cultura Justa y botón de reporte rápido de 1 clic.
R-05	Compromiso de credenciales por canal no cifrado en tránsito	Baja	Muy Alto	**Alto**	Uso obligatorio de IMAPS (puerto 993 con TLS) y deshabilitación de texto plano en Dovecot.
R-06	Acceso ilegítimo al panel de control de simulación	Media	Alto	**Alto**	Confinamiento del panel GoPhish estrictamente a 127.0.0.1:3333 en Linux.

2.5. Acta Simulada de Aprobación de Dirección

- **Entidad:** NOVATEC Soluciones Tecnológicas S.L.
- **Fecha:** 10 de octubre de 2026 | **Versión:** 1.0
- **Reunidos:** Dirección General, Responsable de Red y Servidores (Jorge Higuero Peña), Responsable de Formación y Cumplimiento (Isela Pilar González Primo).

- **Resolución:** Se aprueba el presupuesto de 4.500 € y la ejecución del Plan de Intervención de 90 Días frente al Factor Humano, encomendando la ejecución de simulaciones controladas de ingeniería social y auditorías periódicas de cumplimiento. *(Aprobación pedagógica simulada)*

3. Despliegue de Correo Local y Dos Campañas GoPhish (E2 y E3)

- **Servidor Linux (Bind + Postfix + Dovecot)**

Se desplegó un servidor DNS autoritativo para la zona novatec.test con registros A para mail y ns1, y un registro MX apuntando al servicio de correo. Esta configuración permitió dotar al entorno de un nombre de dominio corporativo (mail.novatec.test), facilitando la generación de URLs absolutas en GoPhish y evitando el uso de IPs sueltas.

Primero, editamos el fichero de configuración local para crear una nueva "zona" (un directorio propio):

```
  GNU nano 7.2                    /etc/bind/named.conf.local
//
// Do any local configuration here
//

// Consider adding the 1918 zones here, if they are not used in your
// organization
//include "/etc/bind/zones.rfc1918";

zone "novatec.test" {
    type master;
    file "/etc/bind/db.novatec.test";
};
```

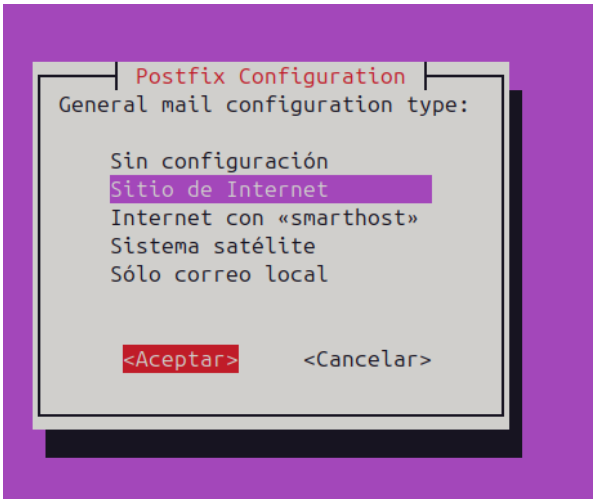
De esta forma, declaramos que Ubuntu es el **maestro** (autoridad máxima) de todo lo que termine en .test.

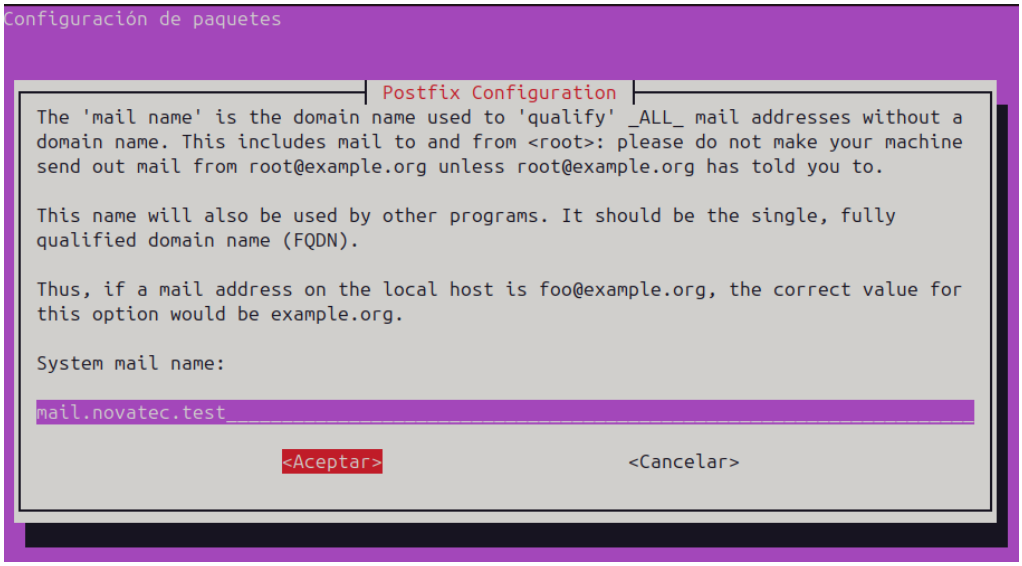
Ahora creamos el fichero donde diremos qué IP pertenece a qué nombre.

```
  GNU nano 7.2                      /etc/bind/db.novatec.test
;
; BIND data file for local loopback interface
;
$TTL    604800
@       IN      SOA     ns1.novatec.test. admin.novatec.test. (
                              2           ; Serial
                         604800           ; Refresh
                          86400           ; Retry
                        2419200           ; Expire
                         604800 )         ; Negative Cache TTL
;
@       IN      NS      ns1.novatec.test.
ns1     IN      A       192.168.10.10
mail    IN      A       192.168.10.10
@       IN      MX 10   mail.novatec.test.
```

Postfix: Motor de correo local

Se configuró Postfix en modo *Internet Site* con entrega local mediante formato Maildir. La seguridad se reforzó restringiendo el reenvío (*relay*) exclusivamente a 127.0.0.0/8 mediante mynetworks y smtpd_relay_restrictions, asegurando que GoPhish pueda enviar mensajes localmente sin ser utilizado como open relay por la red externa.






```
jackis@jackis-VirtualBox:~$ sudo postconf -e "myhostname = mail.novatec.test"
sudo postconf -e "mydomain = novatec.test"
sudo postconf -e "myorigin = novatec.test"
sudo postconf -e "mydestination = \$myhostname, localhost.\$mydomain, localhost, novatec.test"
sudo postconf -e "inet_interfaces = all"
sudo postconf -e "home_mailbox = Maildir/"
sudo postconf -e "mynetworks = 127.0.0.0/8"
sudo postconf -e "smtpd_relay_restrictions = permit_mynetworks, reject_unauth_destination"
sudo systemctl restart postfix
jackis@jackis-VirtualBox:~$
```

3.3. Dovecot: Acceso IMAP seguro

Se habilitó el acceso a buzones en el puerto 993 con cifrado TLS obligatorio (ssl = required). Se generó un certificado autofirmado para validar la autenticación de los clientes (Thunderbird) y se sincronizó la ruta de correo con Postfix (mail_location = maildir:~/Maildir), garantizando la integridad de la entrega.

```
  GNU nano 7.2                    /etc/dovecot/conf.d/10-mail.conf *
#
# There are a few special variables you can use, eg.:
#
#   %u - username
#   %n - user part in user@domain, same as %u if there's no domain
#   %d - domain part in user@domain, empty if there's no domain
#   %h - home directory
#
# See doc/wiki/Variables.txt for full list. Some examples:
#
mail_location = maildir:~/Maildir
#   mail_location = mbox:~/mail:INBOX=/var/mail/%u
#   mail_location = mbox:/var/mail/%d/%1n/%n:INDEX=/var/indexes/%d/%1n/%n
#
# <doc/wiki/MailLocation.txt>
#
```

```
jackis@jackis-VirtualBox:~$ sudo openssl req -x509 -newkey rsa:3072 -nodes -days 30 \
-keyout /etc/ssl/private/novatec-lab.key \
-out /etc/ssl/certs/novatec-lab.crt \
-subj "/CN=mail.novatec.test"
.....+.....+.++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++*..++++++++++++++
++++++++++++++++++++++++++++++++++++++++++++++++*.........................+..............+..
....+....+............+......+........+..................+..................+..................
...+..........+...+...........+...++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++
++++
...+......+.....+.+..+.++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++*.....
..+..+......+.+...+..+.+........+...........+.......+..+.........+......+.........++++++++++++
++++++++++++++++++++++++++++++++++++++++++++++++*......+..............+..................
..+............+.....+....+........+.......+...+..................+...+..+..............+....
........+......+....+...+.........+......+.....+.......+..+.+..+......+..........+........+...
+.....+....+.....+...+.......+......+.....+...+.+.....+..............+.+.....+.........+......
+...+..........+.....+....+..+............+..+......+....+...........+...+.......+...+.....+++
++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++++
-----
jackis@jackis-VirtualBox:~$ sudo chmod 600 /etc/ssl/private/novatec-lab.key
```

```
jackis@jackis-VirtualBox:~$ sudo systemctl restart dovecot
jackis@jackis-VirtualBox:~$ sudo ss -lntp | grep -E ":(25|993) "
LISTEN 0      100                                0.0.0.0:993        0.0.0.0:*    users:(("dov
ecot",pid=9557,fd=36))
LISTEN 0      100                                0.0.0.0:25         0.0.0.0:*    users:(("mas
ter",pid=5715,fd=13))
LISTEN 0      100                                   [::]:993           [::]:*    users:(("dov
ecot",pid=9557,fd=37))
LISTEN 0      100                                   [::]:25            [::]:*    users:(("mas
ter",pid=5715,fd=14))
```

```
jackis@jackis-VirtualBox:~$ sudo doveconf -n | grep ssl_
ssl_cert = </etc/ssl/certs/novatec-lab.crt
ssl_client_ca_dir = /etc/ssl/certs
ssl_dh = # hidden, use -P to show it
ssl_key = # hidden, use -P to show it
```

```
jackis@jackis-VirtualBox:~$ echo "Este es un mensaje de prueba interno" | mail -s "Prueba NOVAT
EC" empleado@novatec.test
jackis@jackis-VirtualBox:~$ sudo ls -la /home/empleado/Maildir/new
total 12
drwxrwxr-x 2 empleado empleado 4096 oct 10 16:42 .
drwxrwxr-x 5 empleado empleado 4096 oct 10 16:41 ..
-rw------- 1 empleado empleado  491 oct 10 16:42 1791643366.V802Ie1b9aM642033.jackis-VirtualBox
jackis@jackis-VirtualBox:~$ sudo journalctl -u postfix --since "10 minutes ago" --no-pager
-- No entries --
```

```
jackis@jackis-VirtualBox:~$ sudo grep postfix /var/log/mail.log | tail -20
2026-10-10T16:31:41.256981+02:00 jackis-VirtualBox postfix/postfix-script[5268]: starting the P
ostfix mail system
2026-10-10T16:31:41.272693+02:00 jackis-VirtualBox postfix/master[5270]: daemon started -- vers
ion 3.8.6, configuration /etc/postfix
2026-10-10T16:32:50.584193+02:00 jackis-VirtualBox postfix/postfix-script[5414]: stopping the P
ostfix mail system
2026-10-10T16:32:50.596848+02:00 jackis-VirtualBox postfix/master[5270]: terminating on signal
15
2026-10-10T16:32:52.734952+02:00 jackis-VirtualBox postfix/postfix-script[5713]: starting the P
ostfix mail system
2026-10-10T16:32:52.751908+02:00 jackis-VirtualBox postfix/master[5715]: daemon started -- vers
ion 3.8.6, configuration /etc/postfix
2026-10-10T16:42:46.584848+02:00 jackis-VirtualBox postfix/pickup[5716]: 8E9E1E1B99: uid=1000 f
rom=<jackis@jackis-VirtualBox>
2026-10-10T16:42:46.619263+02:00 jackis-VirtualBox postfix/cleanup[5836]: 8E9E1E1B99: message-i
d=<20261010144246.8E9E1E1B99@mail.novatec.test>
2026-10-10T16:42:46.626889+02:00 jackis-VirtualBox postfix/qmgr[5717]: 8E9E1E1B99: from=<jackis
@jackis-VirtualBox>, size=388, nrcpt=1 (queue active)
2026-10-10T16:42:46.650630+02:00 jackis-VirtualBox postfix/local[5838]: 8E9E1E1B99: to=<empleac
o@novatec.test>, relay=local, delay=0.12, delays=0.1/0.02/0/0.01, dsn=2.0.0, status=sent (deliv
ered to maildir)
2026-10-10T16:42:46.650996+02:00 jackis-VirtualBox postfix/qmgr[5717]: 8E9E1E1B99: removed
```

3.4. GoPhish: Segmentación de servicios

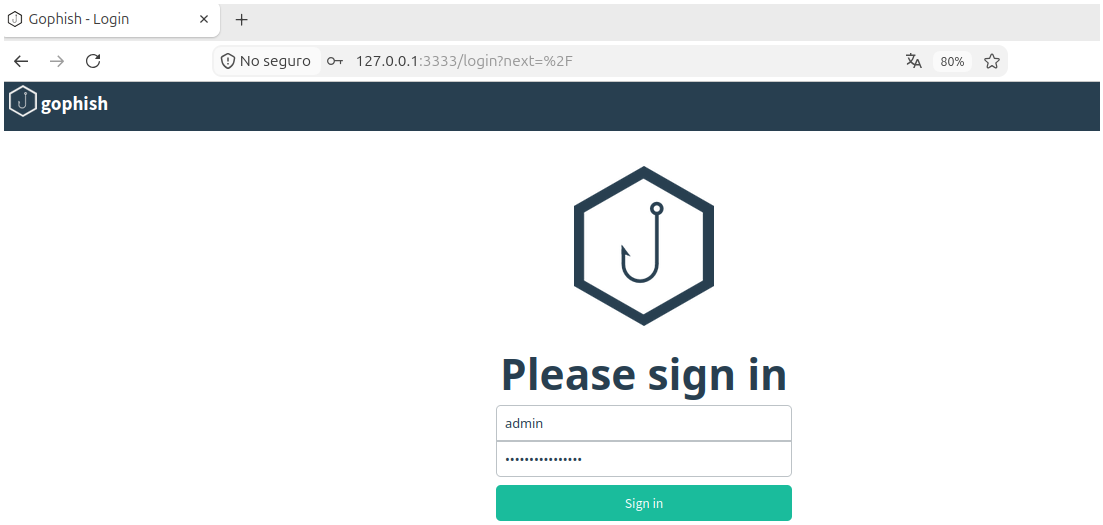
Se configuró GoPhish separando la gestión del ataque:
Panel de Administración: Restringido a 127.0.0.1:3333 para impedir el acceso remoto a los datos de la campaña.
Servidor de Phishing: Escuchando en 0.0.0.0:8080 para servir las landing pages a las víctimas.
Perfil de envío: Configurado para entregar al SMTP local (127.0.0.1:25) sin autenticación, integrando la herramienta con el flujo de correo interno.

```
 GNU nano 7.2                                config.json
{
        "admin_server": {
                "listen_url": "127.0.0.1:3333",
                "use_tls": true,
                "cert_path": "gophish_admin.crt",
                "key_path": "gophish_admin.key",
                "trusted_origins": []
        },
        "phish_server": {
                "listen_url": "0.0.0.0:8080",
                "use_tls": false,
                "cert_path": "example.crt",
                "key_path": "example.key",
                "url": "http://mail.novatec.test:8080"
        },
        "db_name": "sqlite3",
        "db_path": "gophish.db",
        "migrations_prefix": "db/db_",
        "contact_address": "",
                                [ 24 líneas leídas ]
```

Ejecutamos gophish mostrándonos el user y el password necesarios para acceder desde el navegador:

```
jackis@jackis-VirtualBox:~/gophish$ ./gophish
time="2026-10-10T17:37:52+02:00" level=warning msg="No contact address has been configured."
time="2026-10-10T17:37:52+02:00" level=warning msg="Please consider adding a contact_address entr
y in your config.json"
goose: no migrations to run. current version: 20220321133237
time="2026-10-10T17:37:53+02:00" level=info msg="Please login with the username admin and the pas
sword fc53efe185183851"
time="2026-10-10T17:37:53+02:00" level=info msg="Creating new self-signed certificates for admini
stration interface"
time="2026-10-10T17:37:53+02:00" level=info msg="Starting IMAP monitor manager"
time="2026-10-10T17:37:53+02:00" level=info msg="Starting phishing server at http://0.0.0.0:8080"
time="2026-10-10T17:37:53+02:00" level=info msg="Background Worker Started Successfully - Waiting
 for Campaigns"
time="2026-10-10T17:37:53+02:00" level=info msg="Starting new IMAP monitor for user admin"
time="2026-10-10T17:37:53+02:00" level=info msg="TLS Certificate Generation complete"
time="2026-10-10T17:37:53+02:00" level=info msg="Starting admin server at https://127.0.0.1:3333"
```

A continuación, accedemos al navegador con la url: https://127.0.0.1:3333 e introducimos el login y contraseña anteriormente vistos:



- **Cliente Windows (Thunderbird):**

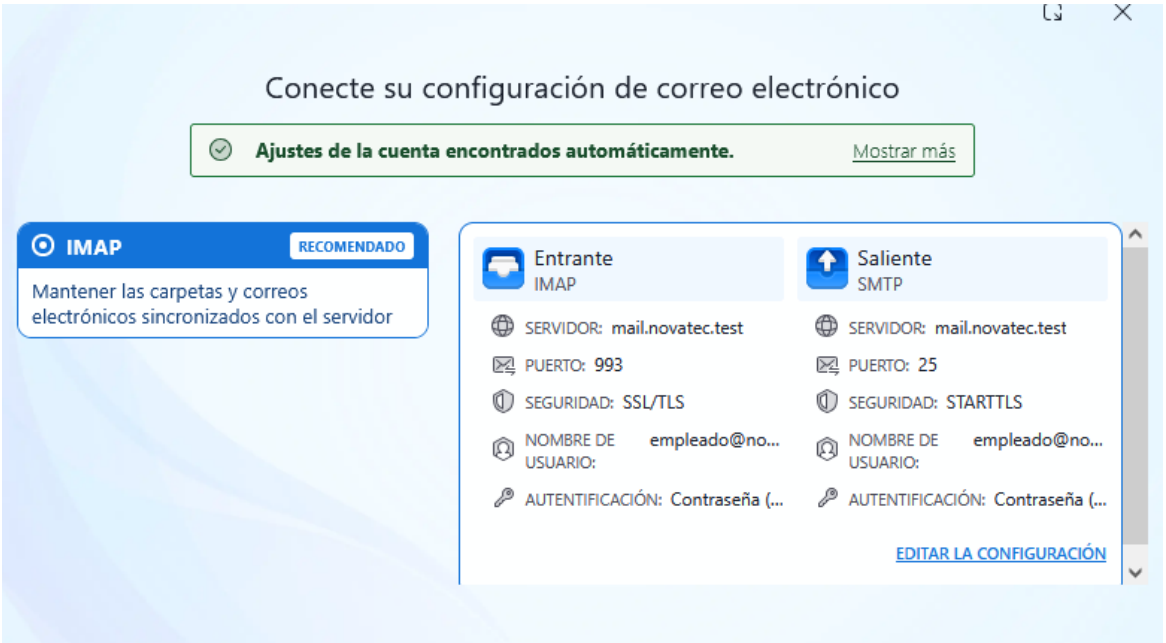
Cuenta de Correo: Se añadió una cuenta existente utilizando las credenciales de laboratorio (empleado@novatec.test / contraseña ficticia).

Servidor Entrante (IMAP):

Servidor: mail.novatec.test (resuelto por DNS).

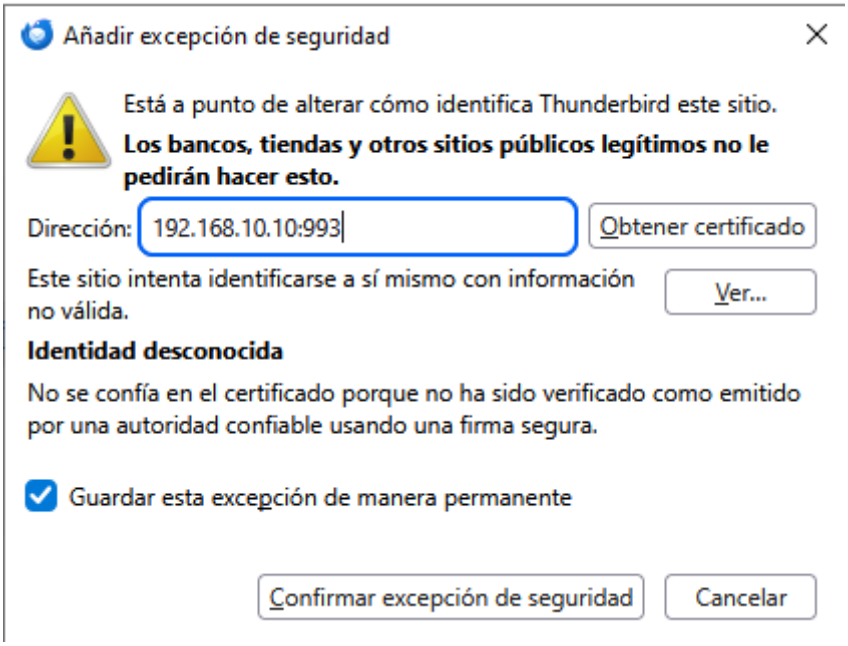
Puerto: 993.

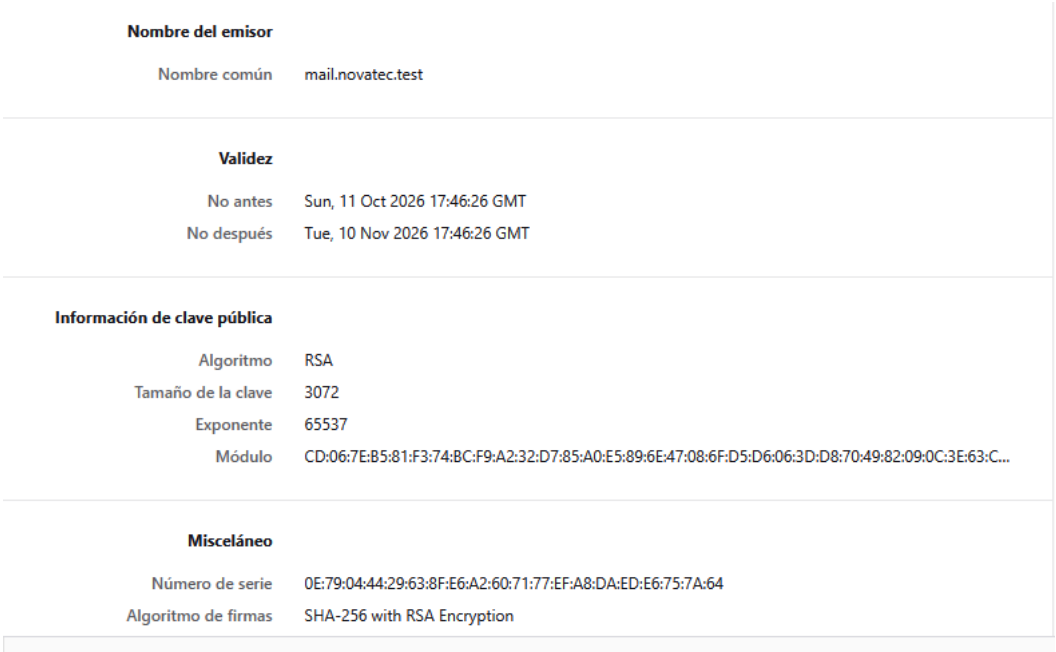
Seguridad: SSL/TLS.



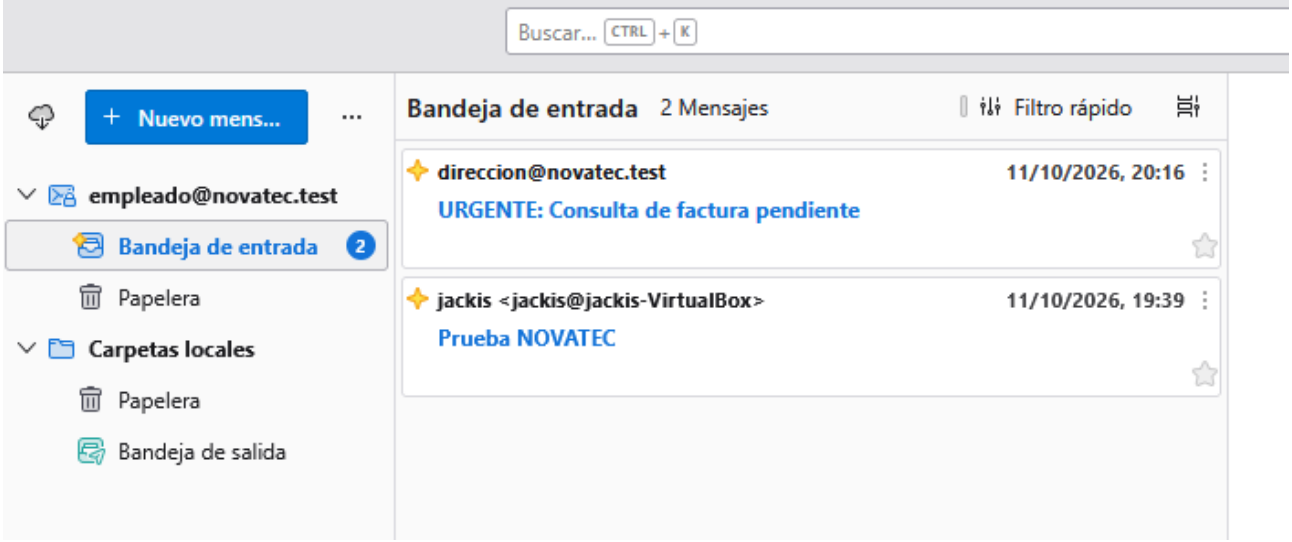
Gestión de Certificados: Al conectarse al servidor Dovecot, Thunderbird mostró una advertencia de certificado autofirmado. Se procedió a generar una excepción de seguridad temporal exclusiva para

este laboratorio, verificando previamente la huella SHA-256 del certificado para asegurar que no se trataba de un ataque de intermediario.





Validación: Se verificó la correcta sincronización de carpetas y la recepción de los correos de prueba y campañas phishing, confirmando que el flujo Postfix → Maildir → Dovecot → Thunderbird operaba correctamente.

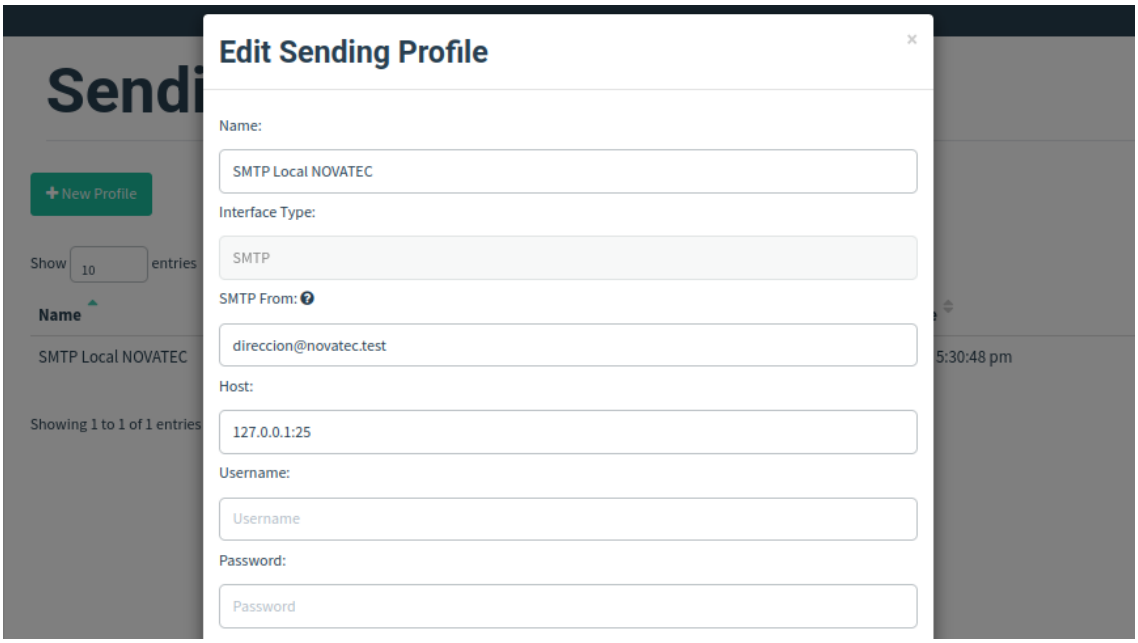


Esta configuración permitió simular fielmente la experiencia del usuario final, incluyendo la gestión de avisos de seguridad (certificados) y la visualización de los enlaces de phishing en un entorno de correo local aislado.

- **Diseño de las dos campañas simuladas en GoPhish:**
  - **Campaña 1 (Administración):** Factura de proveedor vencida reclamando pago urgente. Remitente: direccion@novatec.test. Señales de detección: urgencia excesiva, discrepancia entre el remitente visible.
  - **Campaña 2 (Perfil Técnico):** Falso aviso del departamento de soporte de renovación forzosa de credenciales de acceso. Señales: llamada a la autoridad, petición de verificación de credenciales fuera de canal seguro.
  - **Landing Page Inocua:** Página web en puerto 8080 que únicamente muestra el aviso normativo: *"Simulación formativa: no introduzcas credenciales"*, contabilizando únicamente el clic sin solicitar contraseñas ni registrar datos personales.

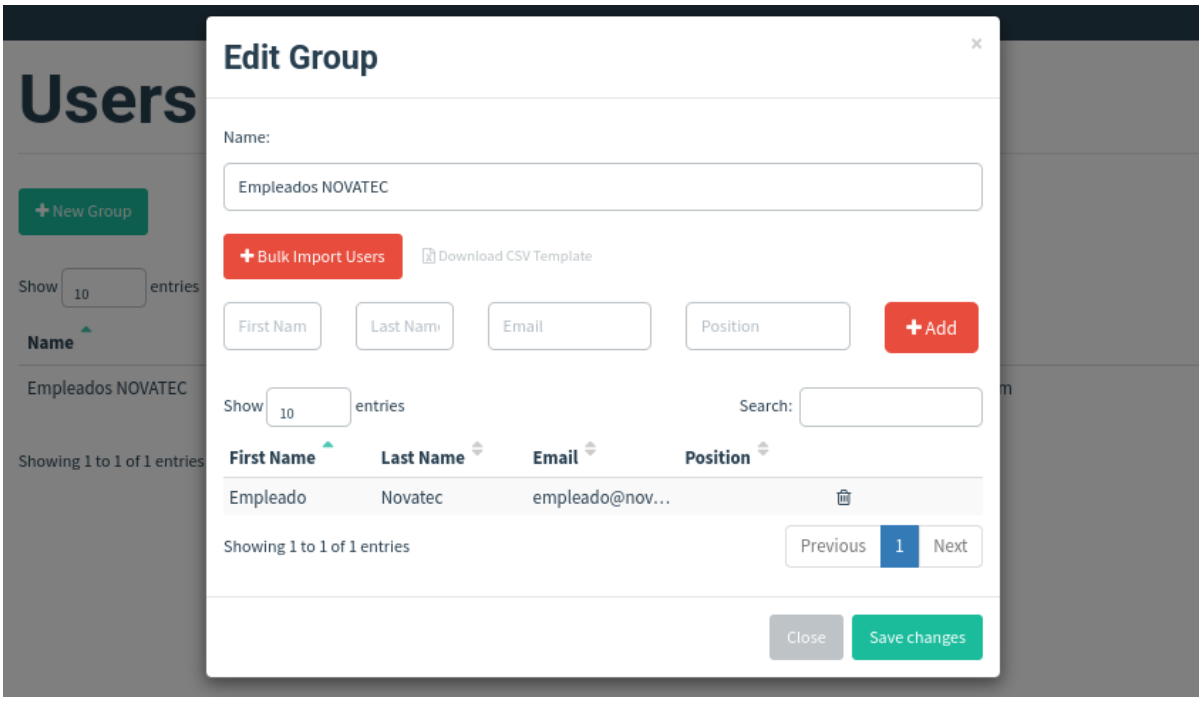
Dentro del dashboard de Gophish generamos:

- Perfil de envío

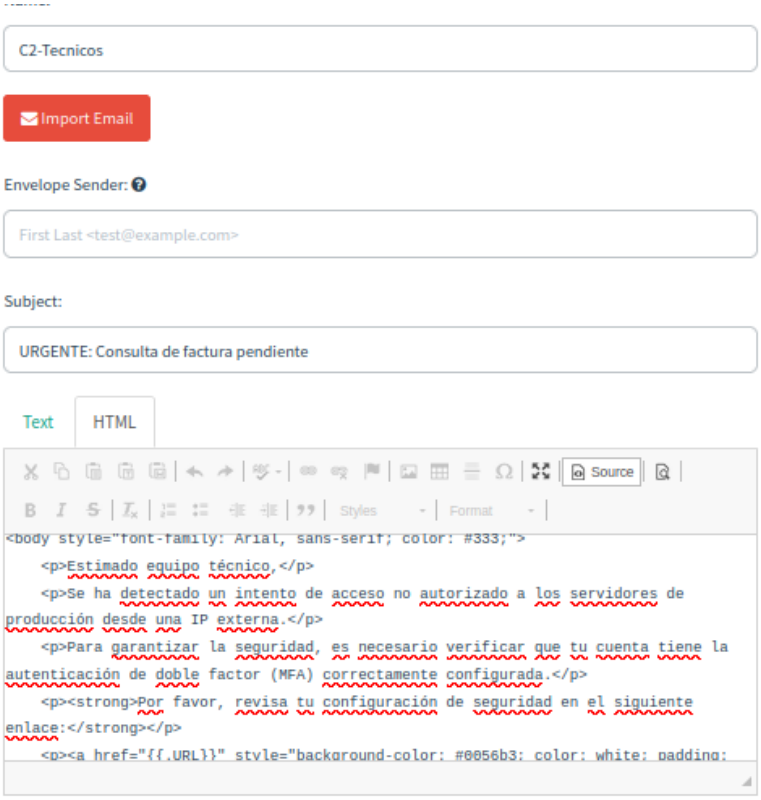


Funciona sin autenticación porque GoPhish y Postfix están en la misma máquina y tu mynetworks = 127.0.0.0/8 autoriza el envío local.

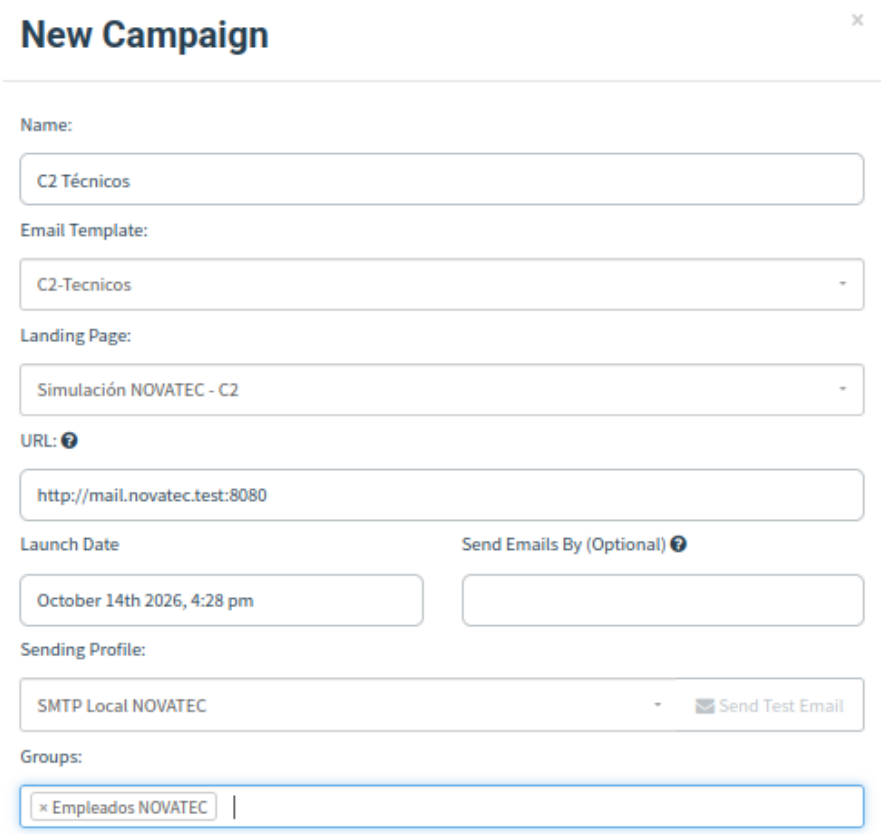
- Grupo de objetivos

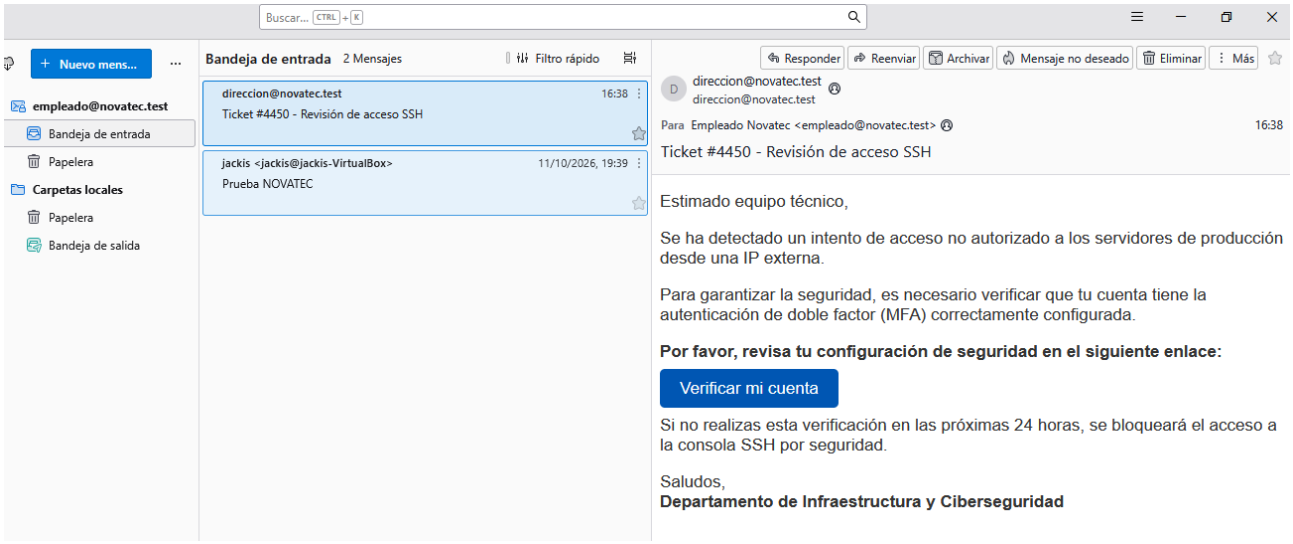


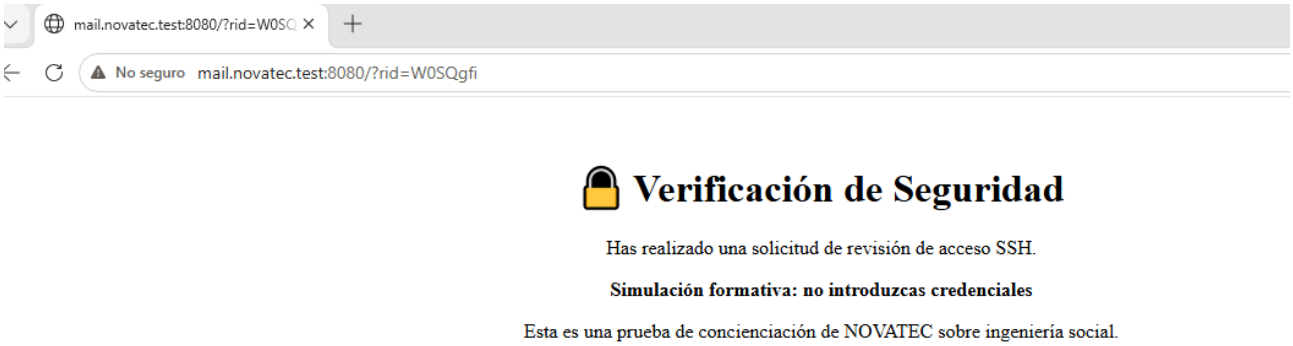
- Plantilla email



- <u>Creación campaña</u>







4. Telemetría y Análisis Técnico (Fase 4)

4.1. Captura e Inspección de Tráfico de Red (tcpdump / Wireshark)

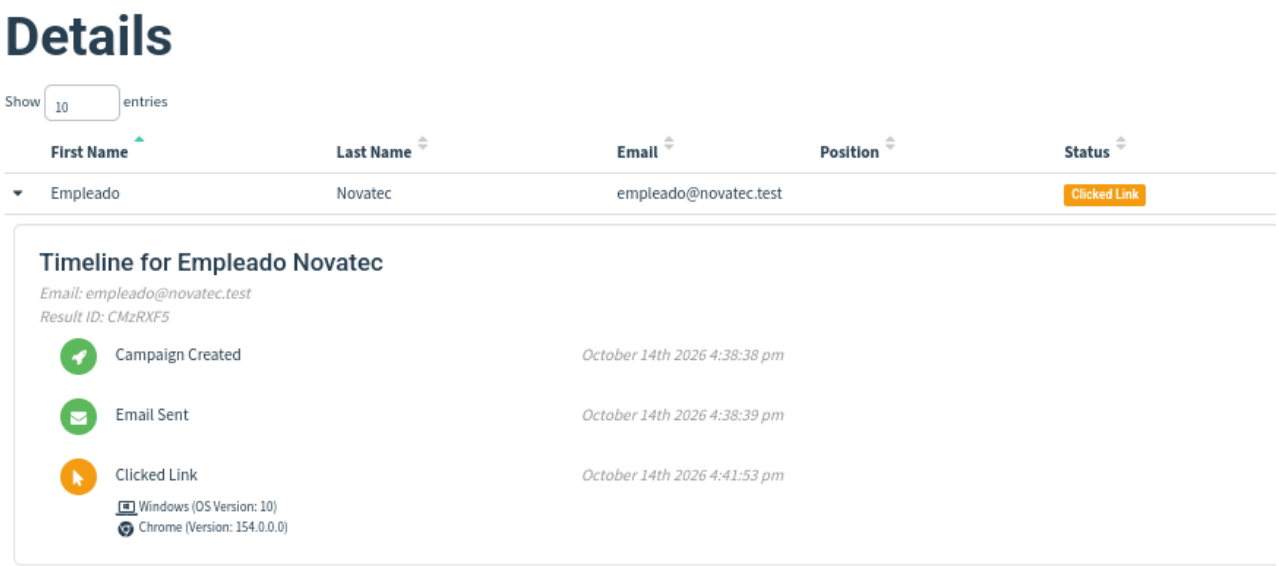
- **Captura de tráfico de red:** Mediante tcpdump y Wireshark filtrando tráfico entre ambas máquinas (host 192.168.10.20 en puertos 25, 993 y 8080).
  - **Puerto 25 (SMTP):** Tráfico interno en texto plano entre GoPhish y Postfix en localhost (127.0.0.1).
  - **Puerto 993 (IMAPS):** Tráfico cifrado mediante TLS entre Windows y Ubuntu; las credenciales y el cuerpo del mensaje no resultan legibles en el volcado de paquetes.
  - **Puerto 8080 (HTTP):** Tráfico web de la landing page; se registra la petición GET del navegador del usuario con su User-Agent e IP de origen.

```
jackis@jackis-VirtualBox:~$ sudo tcpdump -ni enp0s8 -w ~/captura-lab.pcap "host 192.168.1
0.20 and (port 25 or port 993 or port 8080)"
tcpdump: listening on enp0s8, link-type EN10MB (Ethernet), snapshot length 262144 bytes
```



4.2. Correlación de Registros y Confinamiento del Panel

- **Correlación de eventos:** El identificador del mensaje en las cabeceras de Postfix (Message-ID) se correlaciona con el ID de evento en la base de datos de GoPhish y la marca de tiempo de la trama HTTP en la captura de red.
- **Comprobación de seguridad:** Se verifica con ss -lntp que el puerto de administración de GoPhish (3333) está vinculado a 127.0.0.1 y es inaccesible desde Windows.

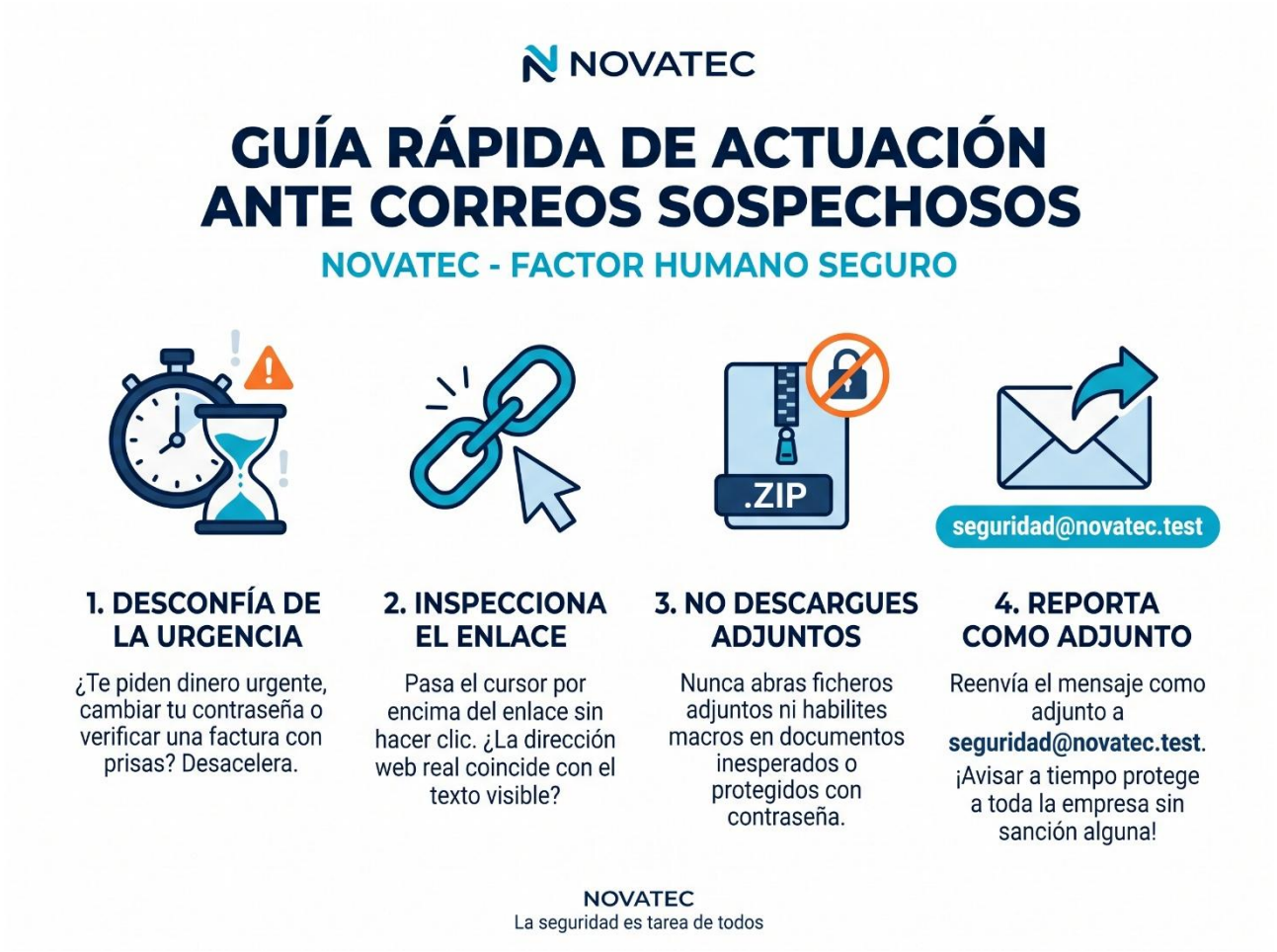


5. Plan de Formación, Seguimiento y Métricas (E4 y E5)

5.1. Microformación de 5 minutos para Administración y Guía Visual

Píldora Formativa (5 minutos): «Detección de Fraude en Facturas»

- **A quién va dirigida:** Personal del departamento de Administración y Finanzas.
- **Objetivo:** Enseñar a identificar correos suplantados que simulan pagos urgentes y aplicar el protocolo de verificación antes de actuar.
- **Guion temporal (5 minutos):**
  - **Minuto 1 (El pretexto):** Se analiza el correo recibido en la campaña C1. Se explica que los atacantes usan la urgencia (*«antes de finalizar la jornada»*) y la firma de la Dirección para que el empleado actúe con prisas sin pararse a pensar.
  - **Minuto 2 (Inspección del enlace):** Cómo pasar el ratón por encima del hipervínculo para comprobar que la dirección real a la que lleva no coincide con la oficial de la empresa.
  - **Minuto 3 (Verificación por canal secundario):** Obligación de llamar por teléfono interno al responsable o proveedor si piden un cambio de número de cuenta o un abono urgente antes de tramitar nada.
  - **Minuto 4 (Protocolo de reporte):** Cómo pulsar el botón de reenvío como archivo adjunto hacia seguridad@novatec.test para que el equipo de IT reciba las cabeceras intactas.
  - **Minuto 5 (Cultura Justa):** Recordatorio de que la seguridad es responsabilidad compartida; avisar a tiempo tras un clic accidental jamás supone una sanción disciplinaria.



5.2. Cuestionario de Evaluación de Decisiones (6 Ítems)

1. **Recibes un correo de "Dirección" pidiendo transferir un pago urgente a un nuevo proveedor.**
   - *Acción correcta:* Contrastar telefónicamente con el departamento emisor a través del número interno oficial antes de hacer cualquier movimiento.
   - *Justificación:* La urgencia y la autoridad son las técnicas principales para anular el juicio crítico.
2. **Un enlace en el correo muestra novatec.test, pero al pasar el ratón apunta a http://192.168.10.10:8080.**
   - *Acción correcta:* No pulsar en el enlace y reportar el mensaje inmediatamente.
   - *Justificación:* El texto visible del hipervínculo es fácilmente falsificable en clientes HTML.
3. **El departamento de TI te envía un correo pidiéndote tu clave temporal por migración.**
   - *Acción correcta:* Marcar como phishing; el departamento de soporte jamás solicita contraseñas por correo (NOR-04).
   - *Justificación:* Los administradores disponen de herramientas para gestionar identidades sin requerir la clave privada.

4. **Has hecho clic por error en un enlace sospechoso.**
    - *Acción correcta:* Cerrar el navegador, no introducir ningún dato y avisar de inmediato a seguridad.
    - *Justificación:* La política de Cultura Justa premia el reporte rápido para activar la contención sin sanción.
5. **Te llega una factura en formato .zip que requiere una contraseña incluida en el texto.**
    - *Acción correcta:* Aislar el archivo y no descomprimirlo.
    - *Justificación:* Los atacantes cifran archivos comprimidos para impedir que los antivirus de pasarela inspeccionen su interior.
6. **¿Por qué se debe reenviar un correo sospechoso como "archivo adjunto" al reportarlo?**
    - *Acción correcta:* Porque preserva intactas las cabeceras técnicas originales (Received, Message-ID, IP de origen) para el análisis del equipo de seguridad.
    - *Justificación:* El reenvío estándar sobrescribe cabeceras y destruye la cadena de custodia de la evidencia técnica.

5.3. Sistema de Indicadores (KPI / KRI)

- KPI-1: Tasa de Clic en Campañas (TC)

$$\text{Tasa de Clic (\%)} = \frac{\text{Usuarios únicos que pulsaron el enlace (clics válidos)}}{\text{Total de correos entregados efectivamente en buzón}} \times 100$$

    - *Fuente:* Registros de eventos GoPhish vinculados con logs de Postfix.
    - *Objetivo:* Reducir la tasa por debajo del 5% en 90 días.

- KPI-2: Tasa de Notificación Correcta (TN)

$$\text{Tasa de Notificación (\%)} = \frac{\text{Reportes válidos recibidos en el canal oficial}}{\text{Total de correos sospechosos entregados}} \times 100$$

    - *Fuente:* Registro de tickets en seguridad@novatec.test.
    - *Objetivo:* Alcanzar un porcentaje de reporte superior al 70%.

- KRI (Key Risk Indicator): Tasa de Reincidencia (TR)

$$\text{Reincidencia (\%)} = \frac{\text{Usuarios con interacción repetida en 2 o más campañas}}{\text{Total de usuarios expuestos a múltiples simulaciones}} \times 100$$

    - *Propósito:* Detectar colectivos o departamentos que requieren formación específica reforzada.

- Métrica Temporal: Tiempo hasta la Notificación (T_{notif})

$$T_{\text{notif}} = t_{\text{reporte}} - t_{\text{entrega}}$$

    - *Objetivo:* Mediana de tiempo de reporte inferior a 45 minutos tras la entrega.

6. Auditoría Cruzada y Mejora Continua (E6 - Fase 6)

6.1. Matriz de Auditoría (8 Requisitos Clave)

ID Requisito	Criterio Auditado	Método / Evidencia Exigida	Estado de Conformidad	Responsable / Plazo
REQ-01	Aprobación formal de política por dirección	Acta simulada con fecha, responsables y presupuesto	**Conforme**	Dirección / 90 días
REQ-02	Existencia de 6 normas auditables de puesto	Documentación formal NOR-01 a NOR-06 verificable	**Conforme**	Cumplimiento / Continuo
REQ-03	Canal y procedimiento de reporte operativo	Procedimiento de 4 pasos y buzón de destino definido	**Conforme**	SOC / 30 días
REQ-04	Aislamiento de red del laboratorio	Verificación de red interna sin salida a Internet activa	**Conforme**	Administrador de Red
REQ-05	Cifrado en tránsito para acceso a buzón	Puerto 993 IMAPS con TLS y plain-auth deshabilitado	**Conforme**	Administrador de Sistemas
REQ-06	Dos campañas de simulación segmentadas	Plantillas C1 (Administración) y C2 (Técnicos) en GoPhish	**Conforme**	Equipo de Seguridad
REQ-07	Landing page inocua sin captura de credenciales	Verificación de código: sin formularios ni campos de clave	**Conforme**	Equipo de Seguridad
REQ-08	Sistema formal de indicadores con denominador definido	Fórmulas explícitas de KPI/KRI con fuentes contrastadas	**Conforme**	Auditoría Interna

7. Anexo: Inteligencia de Ciberamenazas y Monitorización en Fuentes Públicas de Telegram (Enfoque OSINT / CTI)

Para evitar que las campañas de concienciación queden obsoletas, NOVATEC incorpora la monitorización de canales públicos especializados en Threat Intelligence y cibercrimen, emulando la metodología de indexación y detección temprana de plataformas como Byron Labs.

1. **INCIBE - Alertas Oficiales:** Avisos institucionales españoles sobre fraude por correo y campañas de ingeniería social activas.

2. **CCN-CERT Avisos:** Alertas críticas sobre vulnerabilidades y técnicas de compromiso en infraestructuras y administraciones.
3. **vx-underground:** Canal del colectivo de análisis de malware; difusión técnica de señuelos recientes y desensamblado de código malicioso.
4. **Dark Web Informer (@DarkWebInformer):** Monitorización OSINT de mercados clandestinos, filtraciones de datos y compraventa de accesos iniciales (IABs).
5. **Ransomfeed / RansomLook News:** Feed automatizado sobre anuncios de grupos de ransomware y víctimas reportadas.
6. **FalconFeeds.io:** Boletín diario de incidentes globales, desfiguraciones web y ataques de denegación de servicio.
7. **MalwareBazaar (Abuse.ch):** Difusión de hashes y muestras de adjuntos maliciosos (.exe, .xlsm) distribuidos por correo masivo.
8. **PhishStats / OpenPhish Alerts:** Publicación periódica de nuevos dominios de phishing detectados y kits de suplantación web.
9. **The Hacker News:** Canal de noticias internacionales sobre vectores de compromiso de día cero y tendencias en ingeniería social.
10. **BleepingComputer:** Seguimiento en tiempo real de estafas por correo (campañas BEC) y tácticas de ingeniería social emergentes.

7.1. Implementación Técnica: Indexador Automatizado de CTI en Telegram

Como valor añadido y ampliación técnica orientada a la ingeniería del factor humano, se ha implementado un script recolector en Python (telegram_cti_indexer.py). Este módulo automatiza la ingestión y análisis de fuentes abiertas de inteligencia (OSINT/CTI), emulando las metodologías de monitorización de amenazas aplicadas por entidades especializadas del sector como Byron Labs.

El indexador consulta periódicamente los repositorios y canales públicos objetivo, aplica expresiones regulares (Regex) para identificar tendencias activas de ingeniería social (tales como suplantación de facturas, falsos avisos de soporte o bypass de MFA) y genera un volcado estructurado en formato JSON. De este modo, el catálogo de plantillas de GoPhish en NOVATEC no se basa en suposiciones estáticas, sino que se nutre directamente de los pretextos y señuelos reales detectados en circulación.

```
# Fragmento del motor de extracción y análisis de coincidencia (telegram_cti_indexer.py)
for canal in CANALES_TELEGRAM:
    mensajes = obtener_mensajes_publicos(canal)
    for msg in mensajes:
        coincidencias = [p for p in PATRONES_ALERTA if re.search(p, msg, re.IGNORECASE)]
        if coincidencias:
            alertas.append({
                "timestamp": datetime.datetime.now().isoformat(),
                "canal": f"@{canal}",
                "patrones": coincidencias,
                "resumen": msg[:140],
                "aplicacion": "Propuesto para señuelo GoPhish"
            })
```

```
PS C:\Users\isela\Documents\CETI\IC> python telegram_cti_indexer.py
[*] [2026-10-14 04:08:18] Iniciando indexación CTI de Telegram...
[*] Objetivos: 10 canales públicos en radar.
--------------------------------------------------------------------------------
[+] Consultando feed público @incibe              ... [OK] (0 msgs, 0 alertas)
[+] Consultando feed público @CCNCERT             ... [OK] (20 msgs, 1 alertas)
[+] Consultando feed público @DarkWebInformer     ... [OK] (0 msgs, 0 alertas)
[+] Consultando feed público @vxunderground       ... [OK] (24 msgs, 14 alertas)
[+] Consultando feed público @falconfeedsio       ... [OK] (20 msgs, 0 alertas)
[+] Consultando feed público @MalwareBazaar       ... [OK] (0 msgs, 0 alertas)
[+] Consultando feed público @openphish           ... [OK] (0 msgs, 0 alertas)
[+] Consultando feed público @BleepingComputer    ... [OK] (20 msgs, 2 alertas)
[+] Consultando feed público @TheHackerNews       ... [OK] (20 msgs, 4 alertas)
[+] Consultando feed público @RansomfeedNews      ... [OK] (20 msgs, 0 alertas)
--------------------------------------------------------------------------------
[√] Indexación finalizada.
[√] Se han exportado 21 alertas a 'telegram_cti_feeds.json'.
```

